DOCUMENT D01 · ABC BANK

Governance structure and three lines of defence

Extract from ABC Bank's annual risk self-assessment report (year-end 2024), Section 3 – System of Governance

3.1 Governance structure

ABC Bank has established a governance system in compliance with the Banking Ordinance and the HKMA Supervisory Policy Manual (including CG-1 Corporate Governance and IC-1 Risk Management Framework), while also aligning with prevailing international practice.

The governance structure is set out in the shareholder agreement, articles of association, board charter and Board Committee terms of reference. Together with the Executive Committee (EC), the Board sets the tone and assigns responsibilities for managing key risks.

The Board includes 3 independent non-executive directors (INEDs), 3 non-executive directors and 2 executive directors. Each Board Committee — Audit; Risk Management and Compliance; Nomination and Remuneration — is chaired by an INED.

3.2 Risk reporting structure

Level	Role in risk management
Board	Overall responsibility for risk management
Risk Management and Compliance Committee (RMCC)	Includes INEDs; makes recommendations to the Board
Chief Risk Officer (CRO)	Leads the risk management function; reports to the RMCC quarterly
Risk management function	Supports ERM implementation; monitors the risk profile; communicates mitigation strategies and remedial actions

The EC and functional heads meet on a regular basis to discuss current and future management matters. Risk management and compliance topics are a recurrent theme and link ERM with day-to-day management.

3.3 Three lines of defence

1st line — Business units	2nd line — Risk and Compliance	3rd line — Internal Audit
Day-to-day risk management; follow the risk process; apply internal controls and risk responses	Oversee risk management across the bank; provide guidance and direction; risk management framework, oversight and reporting	Independent assessment of risk management; ensure adequate risk control, effective risk management and oversight

The Compliance function, led by the Head of Compliance, ensures the consistency and quality of compliance policies and guidelines and organises training for staff and management, including on cybersecurity. Business and operational functions maintain domain-specific policies, guidelines and manuals that address key risks and delineate roles and responsibilities.

The Internal Audit function is independent and reports directly to the Board via the Audit Committee. It is co-sourced from an external professional services firm and operates under an Internal Audit Policy, following an annual risk-based plan approved by the Audit Committee and the Board.

Sanitised teaching material. Re-typeset extracts of real governance documents; the institution's name, all personal names, addresses, systems, vendors and other identifying details have been changed or removed. Do not attempt to identify the organisation and do not share outside CS5292.